



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
1 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

1. Governance Charter

1.1. Policy Statement

- 1.1.1. Pakistan Cables Ltd. (PCL or the Company) shall operate a centralized IT and cybersecurity governance framework aligned with NIST Cybersecurity Framework (CSF 2.0) and ISO/IEC 27001:2022.
- 1.1.2. This framework shall serve as the primary mechanism for **proactive risk identification** and **threat mitigation**.
- 1.1.3. All digital assets, systems, cloud platforms, AI tools, and technology services shall originate, operate, and be maintained under the IT governance authority. All technology initiatives must undergo a documented risk assessment and centralised procurement, as per IT Software and Hardware procurement policy.

Commented [MD1]: It doesn't state *why* we align (risk mitigation) or how we measure success (compliance).

Commented [SN2R1]: The published NIST framework is the criteria for success.

Commented [SN3R1]:

2. Governance Structure It would be a good practice to include a RACI matrix within the manual to eliminate ambiguity

Commented [SN4]: It has been defined in ITSC Terms of Reference

2.1. Chief Executive Officer (CEO)

- 2.1.1. The CEO is the executive owner of cyber risk.
- 2.1.2. The CEO shall:
 - Approve high-risk exceptions to technology governance policies.
 - Chair or oversee executive-level IT & cybersecurity governance reviews.

2.2. IT Steering Committee (ITSC)

- 2.2.1. The ITSC acts as the operational governance body for technology decisions.
- 2.2.2. Key responsibilities include:
 - Reviewing and approving major IT investments (includes CAPEX and OPEX both above 1.5 Million)
 - Evaluating technology risks and business alignment.
 - Ensuring technology standardization across departments.
 - Monitoring progress of IT and cybersecurity initiatives.
 - Who covers auditory and compliance with the Policy/Framework/Standards?
- 2.2.3. The ITSC shall meet periodically to review:
 - IT risk posture
 - Digital transformation initiatives
 - Technology architecture compliance
 - Vendor and technology risks

Commented [SN5]: Falls under External audit scope



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
2 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

2.3. Business Heads

- 2.3.1. Business heads are owners of digital usage risk within their departments.
- 2.3.2. They are responsible for:
 - Ensuring technology usage within their departments follows IT governance procedures and policies.
 - Submitting justified requests for new technology solutions.
 - Ensuring employees comply with acceptable use and all security requirements.
 - Supporting timely incident reporting and risk mitigation efforts per Company policies and guidelines.
- 2.3.3. Business heads shall not independently procure or deploy or subscribe to technology solutions outside the structured IT governance framework of the Company.
- 2.3.4. Engage the IT Department at the **concept stage** of any new technology requirement to ensure technical compatibility and security alignment.
- 2.3.5. Ensure all third-party vendors undergo the integrated risk assessment (Security, Legal, and Privacy) coordinated by IT before any financial commitment.

Formatted: Font: Not Bold

2.4. Head of IT

- 2.4.1. The Head of IT is responsible for overseeing the design, implementation and rigorous enforcement of IT Governance Framework ~~technology governance~~ to ensure business continuity and data integrity.
- 2.4.2. In case of emergencies such as force majeure, the Head of IT has the authority to suspend any system or service that poses an immediate and unacceptable risk to the Company's digital environment, pending a review by the IT Steering Committee.
- 2.4.3. Responsibilities include:
 - Maintaining technology standards and architecture.
 - Implementing cybersecurity controls aligned with NIST and ISO frameworks.
 - Conducting risk assessments for new technologies.
 - Ensure cross-department compliance with IT governance.
 - Ensure IT governance aligns with corporate strategy.
 - Ensuring compliance monitoring and reporting.

2.5. IT Security Function

- 2.5.1. The IT Security function provides independent oversight of cybersecurity risk.
- 2.5.2. Responsibilities include:



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
3 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

— Performing security risk assessments. (Does this cover periodic audits and maintaining an IT risk register???)

Commented [SN6]: Yes

-
- Monitoring compliance with security controls.
- Investigating cybersecurity incidents.
- Providing advisory support to the ITSC and executive leadership.

3. Digital Acquisition Governance

3.1. All hardware, software, SaaS, AI platforms, and cloud services shall follow the Structured Digital Intake Process:

- Business justification submission via IT Service Desk.
- IT technical and & cybersecurity assessment, including a third party risk assessment for vendors.
- Risk classification
- Approval reference issuance
- Procurement execution
- Asset / license registration
- Secure configuration & deployment

3.2. Procurement and Finance systems shall require IT approval/vetting references before PO issuance or payment release.

3.3. All digital/ technology acquisition requests must enter through IT Service Desk.

3.4. Following details shall be provided:

- Business justification
- Data classification
- Risk category
- Budget owner
- System integration impact

3.5. No digital acquisition, subscription, or technology deployment shall proceed without documented IT authorization.

4. Asset & Configuration Governance

4.1. PCL shall maintain:

- 4.1.1. Centralized Asset Register
- 4.1.2. Software & License Register



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
4 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

4.1.3. SaaS & Cloud Register

4.1.4. AI Tool Register

4.1.5. Vendor Risk Register

4.2. No system shall connect to the corporate network without:

4.2.1. Asset registration

4.2.2. Security baseline configuration

4.2.3. Endpoint protection installation

4.2.4. Identity binding

5. Identity & Access Governance

5.1. All systems must:

5.1.1. Use corporate identity (SSO integration)

5.1.2. Enforce MFA (Multi-factor Authentication) (~~MFA? Define abbreviation~~)

5.1.3. Apply least privilege (~~what about Privilege accounts? Also what happens when the role changes? Maybe an access reset or review upon any change in job role or replacement.~~)

5.1.4. Undergo documented quarterly user access review (after 90 days) undertaken by IT Security team ~~who???~~

5.1.5. Be automatically deprovisioned on exit

5.2. No personal email-based subscriptions permitted.

6. Data Protection & Cloud Governance

6.1. The Company ~~PCL~~ shall ensure:

6.1.1. Encryption at rest and in transit

6.1.2. Data classification enforcement

6.1.3. Cloud vendor due diligence

6.1.4. Data residency evaluation

6.1.5. Exit and ~~&~~data deletion assurance (~~what will this be measured against?~~)

6.2. Upload of PCL data to external platforms without IT authorization is prohibited.

7. Monitoring & Detection

7.1. The Company ~~PCL~~ shall implement:

7.1.1. ~~Centralized~~-Centralised logging

7.1.2. SaaS usage visibility

Commented [SN7]: This will be covered in detail in next policy document pertaining to Access Control & Identity Management

Commented [SN8]: IT Security team reviews the cloud and receives logs from cloud service providers and documents it as artifact with exit document



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
5 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

- 7.1.3. License compliance reviews
- 7.1.4. Vulnerability and patch management
- 7.1.5. Quarterly governance reporting to the CEO

8. Incident Response and Cyber Resilience

- 8.1. The Company PCL shall maintain a structured incident response capability.
- 8.2. The Company shall maintain a computer security incident reporting mechanism, led by the Head of IT, with oversight from the ITSC.
- 8.3. PCL shall maintain:
 - 8.3.1. Incident classification matrix
 - 8.3.2. Ransomware containment protocol
 - 8.3.3. Executive notification procedure
 - 8.3.4. Disaster recovery procedures (RTO/RPO defined)
- 8.4. The incident response lifecycle includes:
 - Detection
 - Containment
 - Investigation
 - Recovery
 - Post-incident review
 - No employee, including Business Heads, shall communicate with the media, customers, or regulators regarding a security incident without explicit authorisation from the CEO.
 - The Head of IT must monitor the status of critical 3rd party providers and report outages to the affected Business Heads.

9. Risk Management & Exceptions

- 9.1. The Business Head requesting the exception must formally "Accept" the risk on behalf of their department.
- 9.2. Exceptions require: (exceptions can also be time bound)
 - Every exception must be accompanied by a documented risk assessment with risk impact analysis conducted by IT, outlining the specific threats introduced by the deviation.
 - Compensating controls
 - CEO approval for high-risk deviations and ITSC's approval for Low & Medium risk deviations (need to define what those are otherwise delegation will not work effectively)

Commented [MD9]: This is vague?

Commented [SN10R9]: Will be detailed in incident response policy

Commented [SN11]: Classification will be done in risk assessment and analysis report as per above clause



IT and Cybersecurity Governance Manual

Page #	Document #	Revision	Revision Date	Effective Date	Custodian
6 of 6	00443	01	March 5, 2026	April 1, 2026	IT Division

- Inclusion in centralized risk register: ~~(approval authority to be aligned by the level of risk ranging between High, Medium, Low)~~

Commented [SN12]: Included in above clause

Commented [SN13]:

APPROVED BY
CHIEF EXECUTIVE OFFICER